



UNIVERSITAT
POLITÈCNICA
DE VALÈNCIA



UNIVERSITAT POLITÈCNICA DE VALÈNCIA

Escuela Técnica Superior de Ingeniería Informática

Implementación de un SIEM Qradar con la integración de
Wazuh, Suricata y PFsense

Trabajo Fin de Máster

Máster Universitario en Ciberseguridad y Ciberinteligencia

AUTOR/A: Vico Burruezo, Mireia

Tutor/a: López Patiño, José Enrique

CURSO ACADÉMICO: 2024/2025



UNIVERSITAT
POLITÈCNICA
DE VALÈNCIA



Escola Tècnica
Superior d'Enginyeria
Informàtica

Escola Tècnica Superior d'Enginyeria Informàtica
Universitat Politècnica de València

Implementación de un SIEM QRadar con la integración de Wazuh, Suricata y PFsense

Trabajo Fin de Máster

**Máster Universitario en Ciberseguridad y
Ciberinteligencia**

Autor: Mireia Vico Burruezo

Tutor: José Enrique López Patiño

2024/2025

Resum

En el següent treball es realitza la implementació d'un SOC (Centre d'Operacions de Seguretat) utilitzant una combinació d'eines i tecnologies per a la monitorització d'esdeveniments de xarxa. Per a açò s'implementa un SIEM (Sistema d'Informació i Gestió d'Esdeveniments de Seguretat) utilitzant la solució de QRadar d'IBM. A més, s'integren dos sistemes de detecció d'intrusos tant a nivell de dispositiu com de xarxa, que són un HIDS (Sistema de Detecció d'Intrusos en dispositius) i un NIDS (Sistema de Detecció d'Intrusos en Xarxa), respectivament. La tecnologia utilitzada per al HIDS és Wazuh i per al NIDS és Suricata. També s'integra el firewall pfsense per a tindre una major visibilitat de xarxa. Finalment, es realitzen casos d'ús per a les regles de detecció.

Paraules clau: SOC; SIEM; HIDS; NIDS; firewall; xarxa; monitorització

Resumen

En el siguiente trabajo se realiza la implementación de un SOC (Centro de Operaciones de Seguridad) utilizando una combinación de herramientas y tecnologías para la monitorización de eventos de red. Para esto se implementa un SIEM (Sistema de información y gestión de eventos de seguridad) utilizando la solución de QRadar de IBM. Además, se integra dos sistemas de detección de intrusos tanto a nivel de dispositivo como de red, que son un HIDS (Sistema de detección de intrusos de dispositivos) y NIDS (Sistema de intrusos en red), respectivamente. La tecnología utilizada para el HIDS es Wazuh y para el NIDS Suricata. También se integra el firewall pfsense para tener una mayor visibilidad de red. Por último, se realiza casos de uso para las reglas de detección.

Palabras clave: SOC; SIEM; HIDS; NIDS; firewall; red; monitorización

Abstract

In the following work, a SOC (Security Operations Center) is implemented using a combination of tools and technologies for network event monitoring. For this purpose, a SIEM (Security Information and Event Management System) is implemented using IBM's QRadar solution. In addition, two intrusion detection systems are integrated at both device and network level, which are a HIDS (Device Intrusion Detection System) and NIDS (Network Intrusion Detection System), respectively. The technology used for HIDS is Wazuh and for NIDS Suricata. The pfsense firewall is also integrated for greater network visibility. Finally, use cases for the detection rules are made.

Keywords: SOC; SIEM; HIDS; NIDS; firewall; network; monitoring

Tabla de contenidos

1.	Introducción.....	9
1.1	Motivación.....	9
1.2	Objetivos.....	10
1.3	Impacto esperado.....	11
2	Contexto tecnológico.....	13
2.1	Crítica al estado del arte	13
2.2	Propuesta	14
3	Diseño de la solución.....	15
3.1	Arquitectura del sistema.....	15
3.2	Diseño detallado.....	16
3.3	Tecnología utilizada.....	17
4	Implantación.....	19
4.1	Instalación y configuración pfsense	19
4.1.1	Creación reglas PFsense	22
4.2	Instalación y configuración QRadar	23
4.2.1	Problemas encontrados	24
4.3	Instalación y configuración Wazuh.....	26
4.3.1	Instalación y configuración Wazuh server	26
4.3.2	Instalación y configuración agente Wazuh	27
4.4	Instalación y configuración Suricata	28
4.4.1	Reglas Suricata	30
5	Integraciones.....	33
5.1	Integración Wazuh.....	34
5.2	Integración Suricata.....	37
5.3	Integración pfSense.....	38
6	Pruebas	41
6.1	Pruebas Suricata	41
6.2	Pruebas pfsense.....	44
6.3	Pruebas Wazuh	44
7	Monitorización	47
7.1	Reglas PFsense	47
7.2	Reglas suricata.....	48

7.3	Reglas Wazuh	49
8	Conclusiones	51
8.1	Relación del trabajo desarrollado con los estudios cursados	52
8.2	Trabajos futuros.....	52
9	Bibliografía	54

Tabla de ilustraciones

Ilustración 1. Diseño de la solución.....	15
Ilustración 2. Configuración red VMware.....	19
Ilustración 3. Tarjeta de red PFSense.....	20
Ilustración 4. Configuración VMnet8 host anfitrión.....	20
Ilustración 5. Configuración red PFSense.....	21
Ilustración 6. Reglas por defecto PFSense.....	21
Ilustración 7. Configuración reglas WAN.....	22
Ilustración 8. Configuración reglas LAN.....	23
Ilustración 9. Error log activity.....	24
Ilustración 10. Error servicio Ariel.....	24
Ilustración 11. Error qradar.log.....	24
Ilustración 12. Error QRadar.....	26
Ilustración 13. Agente conectado.....	27
Ilustración 14. Configuración suricata paso 1.....	28
Ilustración 15. Configuración suricata paso 2.....	28
Ilustración 16. Configuración suricata paso 3.....	29
Ilustración 17. Configuración suricata paso 4.....	29
Ilustración 18. Ruta fichero reglas Suricata.....	30
Ilustración 19. Habilitar syslog de Wazuh a QRadar.....	34
Ilustración 20. DSM Wazuh.....	34
Ilustración 21. Creación log source Wazuh.....	35
Ilustración 22. Mapeo eventID.....	35
Ilustración 23. Mapeo eventCategory.....	36
Ilustración 24. Evento mapeado wazuh.....	36
Ilustración 25. Campo hostname.....	36
Ilustración 26. Campo user agent.....	37
Ilustración 27. Integración QRadar de Suricata.....	37
Ilustración 28. Syslog para integración de Suricata.....	37
Ilustración 29. Configuración syslog pfsense.....	39
Ilustración 30. Eventos unknown pfsense.....	39
Ilustración 31. Instalación DSM pfsense.....	40
Ilustración 32. Autodetección habilitada.....	40
Ilustración 33. Log suricata.....	41
Ilustración 34. Evento generado regla suricata en QRadar.....	42
Ilustración 35. Evento generado regla suricata en QRadar.....	42
Ilustración 36. Alertas suricata.....	43
Ilustración 37. Alertas Suricata en QRadar.....	44
Ilustración 38. Registro pfsense en qradar.....	44
Ilustración 39. Log logon failure.....	44
Ilustración 40. Log user account delete.....	45
Ilustración 41. Log autorun.....	45
Ilustración 42. Log clave de registro añadida.....	45
Ilustración 43. Log clave de registro eliminada.....	45
Ilustración 44. Ofensa PFSense.....	47

Ilustración 45. Regla fuerza bruta exitosa.....	49
---	----

1. Introducción

En este proyecto se va a instalar y configurar un sistema de gestión de eventos e información de seguridad (SIEM), el cual se utilizará QRadar. En este se integrará un sistema de detección de intrusiones basado en *host* (HIDS) usando Wazuh, un sistema de detección de intrusiones en red (NIDS) empleando Suricata, y el firewall pfSense. Este SIEM permitirá monitorizar y centralizar todos los eventos de seguridad en un mismo lugar, así se consigue una gestión más eficaz. A partir de ahora a cada uno de los componentes se nombrará a estos con sus siglas.

Para realizar esto, se instalará y configurará el SIEM en máquinas virtuales. Estas máquinas están configuradas entre sí para simular una red privada y que se pueda monitorizar el tráfico de red.

Wazuh se utilizará como HIDS para monitorizar la actividad de un equipo Windows, y así detectar comportamientos anómalos y amenazas. En el caso del NIDS, que se utilizará Suricata, el funcionamiento es similar. Sin embargo, a diferencia del HIDS este inspeccionará el tráfico de la red en lugar de los registros del equipo. El firewall PfSense se configurará para filtrar el tráfico de entrada y salida, estableciendo políticas de seguridad. Además, el firewall enviará los eventos al SIEM para monitorizar el tráfico de entrada y salida.

Después de completar la instalación y configuración de cada componente, y recibiendo los eventos de las diferentes fuentes (cada uno de los componentes integrados en el SIEM se denomina fuente), se creará reglas para detectar los comportamientos anómalos y amenazas en la red. También se comprobará que las políticas del firewall son efectivas y se deniega o acepta los paquetes de entrada y salida de la red.

1.1 Motivación

La elección para realizar este trabajo sobre la implementación de un SIEM surge de la necesidad de proteger la red y la información crítica frente a las crecientes amenazas. En la actualidad, es necesario aplicar medidas de seguridad, pero también de detección ya que en un entorno dinámico y en constante evolución es difícil mantener actualizadas todas las medidas de seguridad. Por tanto, si se detecta un comportamiento anómalo este puede ser detectado a través del SIEM.

La integración de un SIEM permite centralizar todos los eventos y así tener una visibilidad de la infraestructura de red para obtener respuestas más rápidas y coordinada ante posibles ataques. De esta manera, se minimiza el impacto de los incidentes de seguridad ya que el tiempo de detección disminuye. También se puede obtener mayor visibilidad de un mismo equipo ya que se no solo se monitoriza su actividad sino también su actividad dentro de la red.

Por otro lado, la implementación de un SIEM no solo mejora la seguridad de la red en cuestión, sino que también puede ser utilizado para investigar nuevos tipos de ataques y ver cuál es su comportamiento. A través de esta actividad proactiva, denominada *threat hunting*, se pueden generar nuevas reglas para detectar nuevas amenazas.

1.2 Objetivos

El principal objetivo de este trabajo es centralizar los eventos de seguridad de diversas fuentes para detectar posibles amenazas de manera más eficiente. A partir de este objetivo principal, surgen otros objetivos importantes. Uno de ellos es complementar las medidas de seguridad ya existentes, cómo puede ser un EDR (*Endpoint Detection and Response*). También mejorar la visibilidad general de red y así disminuir el tiempo de actuación de comportamientos anómalos y posibles ataques.

Otro objetivo clave es reducir vulnerabilidades. Al proporcionar una vista integral de la actividad de la red y los equipos, el SIEM ayuda a identificar puntos débiles y áreas susceptibles de ser explotadas por atacantes. Esto facilita la implementación de medidas correctivas y preventivas, fortaleciendo así la postura de seguridad de la organización.

La integración de un SIEM no solo refuerza la capacidad de detección de amenazas, sino que también permite realizar actividades proactivas en la búsqueda de nuevas amenazas. En lugar de reaccionar únicamente a los incidentes conocidos, el SIEM permite explorar patrones y anomalías que podrían indicar amenazas nuevas. Esta proactividad es esencial para mantenerse un paso adelante de los atacantes y proteger la red de nuevas amenazas.

Finalmente, un objetivo derivado de esta actividad proactiva es la compartir conocimientos sobre nuevas amenazas. Al identificar y analizar nuevas tácticas, técnicas y procedimientos utilizados por los atacantes, se genera conocimiento que puede ser compartido con la comunidad de seguridad. Esto no solo mejora la capacidad de defensa, sino que también contribuye al fortalecimiento de la seguridad global al informar a otros sobre las amenazas emergentes. También generar IOC (Indicadores de compromiso), con estos se pueden crear listas de IPs, u otros tipos de listas. Son de utilidad ya que estos se pueden extraer de un Ciberataque y así utilizarse en otros sistemas.

1.3 Impacto esperado

Uno de los principales impactos esperados es mejorar la detección de amenazas. Implementar un SIEM permite identificar de manera temprana un comportamiento anómalo y correlacionar eventos que podrían indicar actividades maliciosas. Además, se espera una respuesta más rápida y eficaz ante incidentes de seguridad. Reduciendo significativamente el tiempo de reacción y minimizando el impacto de los ataques.

Otro impacto importante, al contener eventos de múltiples fuentes, es facilitar las auditorías y el monitoreo continuo. En este caso el proyecto no está enfocado para una organización, pero también puede ser de gran utilidad para esto, ya que ayuda a cumplir con requisitos normativos y de cumplimiento. Por otro lado, fortalece las políticas de seguridad mediante la configuración de reglas y alertas personalizadas [1]. A nivel de una organización asegura el cumplimiento de políticas internas de seguridad y mejora la capacidad de respuesta frente a incumplimientos de políticas de seguridad y normativa. Un ejemplo de esto sería las exfiltraciones de datos.

Finalmente, la creación de un proyecto SIEM no solo beneficia a una organización específica, sino que también fortalece la comunidad de ciberseguridad. Esto se puede realizar compartiendo conocimientos y mejores prácticas contribuye a luchar contra las amenazas cada vez más sofisticadas.

2 Contexto tecnológico

2.1 Crítica al estado del arte

La implementación de un SIEM, como se comenta en el punto anterior, se trata de una protección de la red frente a amenazas [1]. Otro aspecto importante es la proactividad en la detección de nuevas amenazas. No obstante, a pesar de sus ventajas, el uso de SIEM tiene sus limitaciones.

En primer lugar, la complejidad de la configuración del SIEM puede ser un gran impedimento ya que este requiere un tiempo y conocimiento para poder desarrollarlo para su buen funcionamiento. La centralización de eventos de seguridad y la integración de múltiples fuentes de datos requieren de tiempo y recursos. La configuración inicial, así como el ajuste continuo de las reglas, requiere de un conocimiento y trabajo continuo.

Además, la cantidad masiva de datos generados y recopilados, por el SIEM, puede acabar dificultando la calidad y precisión de los datos que procesa. Uno de los principales problemas es que la propia herramienta limita el número de eventos que recibe, el resultado es que los eventos son descartados y la información se pierde. También la generación de grandes volúmenes de alertas puede conducir a falsos positivos, dificultando la identificación de amenazas reales. Este problema puede causar que disminuya la eficiencia y efectividad del sistema [1].

Finalmente, se encuentra la proactividad en detectar amenazas, pero esto requiere un continuo trabajo y mantenerse actualizado de las últimas amenazas.

Como se ha explicado, aunque la implementación de un SIEM ofrece numerosos beneficios en términos de detección a amenazas, también presenta desafíos relacionados con la complejidad de la implementación, la gestión de grandes volúmenes de datos, proactividad en la detección de nuevas amenazas, y la necesidad del continuo trabajo. Estos aspectos deben ser considerados y gestionados para maximizar la eficacia de un SIEM.

2.2 Propuesta

Para la configuración del SIEM se ha elegido QRadar debido a su alta integrabilidad con una amplia cantidad de fuentes, lo que permite centralizar los datos de manera efectiva y almacenar eventos de Wazuh, Suricata, pfSense y otros sistemas en un solo lugar [2]. QRadar ofrece capacidades avanzadas de visualización y generación de informes automáticos con gráficos, permitiendo una interpretación clara de los eventos que no requieren de alertas para poder analizarlos. Además, se trata de una herramienta extensamente utilizada y hay mucha documentación al respecto de esta. Aunque sea una herramienta de pago, dispone de una versión gratuita con limitaciones. QRadar se destaca por su alta capacidad de integración y escalabilidad en comparación con otras soluciones SIEM como Splunk, ArcSight o LogRhythm [3]. Existe el SIEM Microsoft Sentinel, que también es una herramienta potente, pero esta es de pago.

Wazuh, una plataforma de código abierto, que cuenta con una comunidad activa de desarrolladores y usuarios. Esto garantiza un flujo constante de actualizaciones, mejoras y soporte técnico sin costos adicionales de licenciamiento. También proporciona robustas capacidades de detección de intrusiones en los equipos, monitorizando registros y procesos en tiempo real, y es compatible con sistemas operativos Windows y Linux [4]. Su fácil integración con SIEMs como QRadar permite la transmisión de eventos de seguridad, facilitando la administración centralizada de múltiples equipos en un mismo lugar.

Suricata, elegido como NIDS, es un motor de detección de intrusiones en red de alto rendimiento capaz de analizar tráfico en tiempo real a altas velocidades. Su capacidad para monitorizar el tráfico en profundidad lo hace adecuado para cualquier tamaño de red. Al igual que Wazuh, es una herramienta gratuita que utiliza firmas para detectar amenazas conocidas e identificar comportamientos anómalos [5]. Su compatibilidad con QRadar permite una integración eficaz de eventos de red, mejorando la visibilidad de la red.

Por último, pfSense ha sido seleccionado como firewall debido a su flexibilidad como solución de código abierto y sus capacidades para controlar el tráfico de red [6]. Su interfaz intuitiva y una comunidad activa facilitan la gestión y resolución de problemas, mientras que su rendimiento estable y actualizaciones continuas aseguran una protección confiable.

La elección de QRadar como SIEM, Wazuh como HIDS, Suricata como NIDS y pfSense como firewall se basa en sus capacidades avanzadas de detección y análisis, integración efectiva y facilidad de uso. Implementadas juntas permiten una visibilidad completa y una respuesta rápida y eficaz a las amenazas que puedan surgir. Así se asegura la protección de equipos e información sensible.

3 Diseño de la solución

El diseño de la solución incluirá un desglose detallado de la arquitectura del sistema a alto nivel, y en el punto 3.2 se entra en detalle de las especificaciones técnicas y funcionales de cada uno de los componentes. También de las interfaces de red que se configura para cada uno de ellos.

3.1 Arquitectura del sistema

En la ilustración 1 se presenta la arquitectura propuesta para el desarrollo del trabajo. La arquitectura se divide en dos partes fundamentales la red WAN, donde se encuentra configurado el DHCP para que los equipos se conecten tengan IPs dinámicas. En esta se encuentra un equipo Windows que se utiliza para la monitorización de Wazuh. Por otro lado, la red LAN con IPs estáticas, donde se están todos los componentes que forman parte de la solución de monitorización y una máquina virtual Kali Linux para realizar pruebas posteriormente. Las dos subredes se crean con pfSense, que tiene dos interfaces de red cada una en una de las redes.

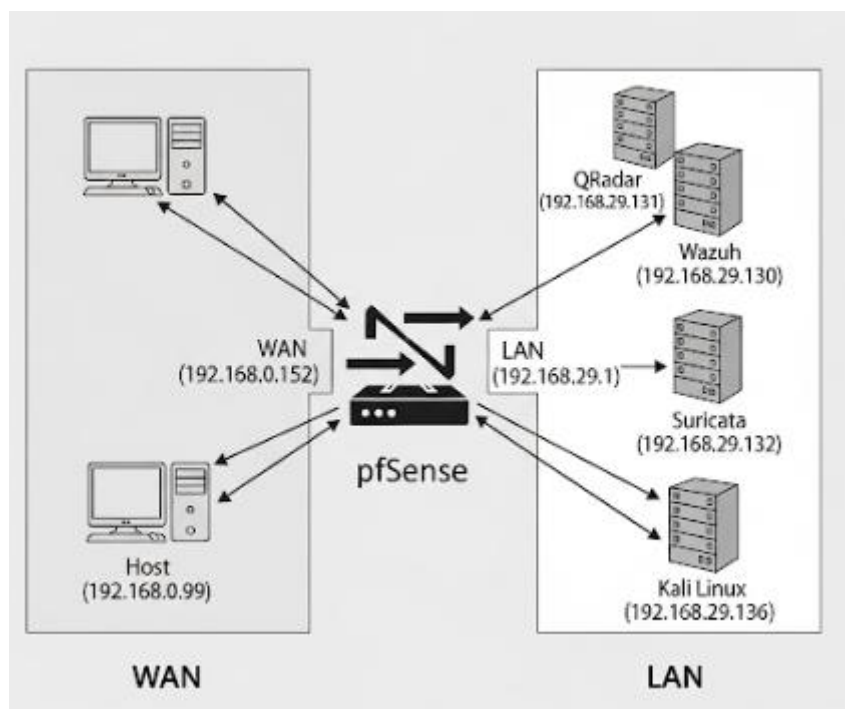


Ilustración 1. Diseño de la solución

Para la monitorización de Wazuh se utiliza un equipo con Windows 10, donde se instala el agente de Wazuh que conecta al Wazuh server. La máquina Windows se trata del host anfitrión donde se instala las demás máquinas virtuales. También se utiliza una máquina Kali Linux para poder realizar diferentes pruebas y comprobar el correcto funcionamiento tanto de Suricata como Pfsense. Debido a que esta máquina simula ataques a la red y estas dos últimas son las encargadas de la detección.

3.2 Diseño detallado

Para la instalación de los componentes es necesario requisitos mínimos a nivel de hardware y software. De esta forma se asegura que los sistemas puedan procesar los datos de seguridad en tiempo real ni perder registros importantes. A continuación, se encuentran unas tablas con los diferentes requisitos necesarios para cada una de las máquinas.

- Requisitos Qradar:

Memoria	8 GB
Disco	250 GB
CPU	Mínimo 2 (recomendable 4)
Interfaz de red	NAT
Sistema operativo	CentOs

- Requisitos Wazuh:

Memoria	2 GB
Disco	50 GB
CPU	4
Sistema Operativo (recomendado)	Ubuntu/CentOS/Debian

- Requisitos pfSense:

Memoria	1 GB
Disco	1 GB
CPU	1
Sistema Operativo	Es propio

- En el caso de suricata se instala en un sistema operativo Ubuntu Server versión 22. No requiere de unas especificaciones mínimas solo las que el propio sistema operativo necesite.

3.3 Tecnología utilizada

Las herramientas usadas para la monitorización se integran en un entorno de virtualización mediante VMware, lo que permite la creación y administración de múltiples máquinas virtuales de forma unificada. Esta tecnología responde a la necesidad de optimizar el uso de los recursos físicos disponibles, garantizando flexibilidad en la asignación de CPU, memoria y almacenamiento, además de ofrecer la posibilidad de realizar ajustes dinámicos según los requerimientos de cada servicio [7]. También es elegida porque la versión pro es gratuita y permite una mayor flexibilidad a la hora de configurar las máquinas.

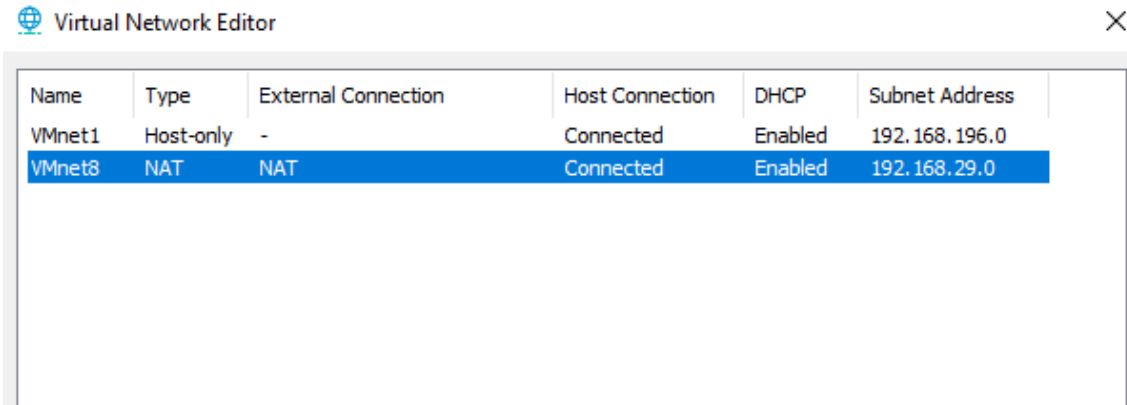
Las máquinas virtuales se encuentran interconectadas a través de una red de tipo NAT (Network Address Translation) configurada en VMware. Se eligió esta opción en lugar de “bridged” o “host-only” porque proporciona aislamiento y conectividad. Por un lado, permite que todas las máquinas virtuales se comuniquen entre sí dentro de un mismo segmento de red privado; y por otro, garantiza acceso controlado hacia el exterior mediante la traducción de direcciones a través del host. De esta manera, se logra mantener un entorno seguro de pruebas y simulaciones sin exponer directamente las máquinas virtuales a la red física o a direcciones IP públicas. [8]

En comparación con otras configuraciones, la red bridged conecta cada máquina virtual directamente a la red física, lo cual ofrece mayor realismo, pero incrementa significativamente la exposición y los riesgos de seguridad. La red host-only, por su parte, restringe totalmente el acceso al exterior y limita la conectividad únicamente al host, lo cual resulta útil en escenarios de aislamiento completo, pero no satisface la necesidad de conectividad hacia servicios externos. En este contexto, NAT representa la opción más adecuada, al conjugar acceso controlado al exterior con un nivel suficiente de aislamiento y seguridad para entornos de laboratorio [9].

4 Implantación

A continuación, se detallará la implantación de las distintas partes que componen la solución de seguridad. En el punto 6 se tratará las integraciones de Wazuh, Suricata y pfSense en QRadar, y en la parte 7 la administración de QRadar.

Antes de empezar con la instalación y configuración de máquinas se revisa que este creada una red NAT (VMnet8), como se puede observar en la ilustración 2. Así las máquinas con interfaz de red de tipo la NAT y que pertenecen a la misma red.



The screenshot shows the 'Virtual Network Editor' window. It contains a table with the following data:

Name	Type	External Connection	Host Connection	DHCP	Subnet Address
VMnet1	Host-only	-	Connected	Enabled	192.168.196.0
VMnet8	NAT	NAT	Connected	Enabled	192.168.29.0

Ilustración 2. Configuración red VMware

4.1 Instalación y configuración pfsense

La instalación pfSense se realiza con la *iso* (imagen del sistema operativo) que se descarga directamente de la web del proveedor. En la máquina virtual, una vez añadida la *iso*, se crean dos adaptadores de red, una está en modo puente simulando así la red WAN, y el segundo adaptador de red está en modo NAT siendo esta la red LAN. De esta forma pfSense controla el tráfico de ambas redes. En la ilustración 3 aparece creadas los dos adaptadores de red junto a los requisitos que se han añadido [9].

Device	Summary
Memory	256 MB
Processors	1
Hard Disk (SCSI)	10 GB
CD/DVD (IDE)	Using file C:\Users\USUARIO\...
Network Adapter	Bridged (Automatic)
Network Adapter 2	Custom (VMnet8)
USB Controller	Present
Sound Card	Auto detect
Display	Auto detect

Ilustración 3. Tarjeta de red PFsense

Por otro lado, en el host anfitrión se habilita el adaptador de red VMnet8 y añade una dirección IP, así se puede acceder al panel de administración de PFsense. En la ilustración 4 se aprecia la configuración [9].

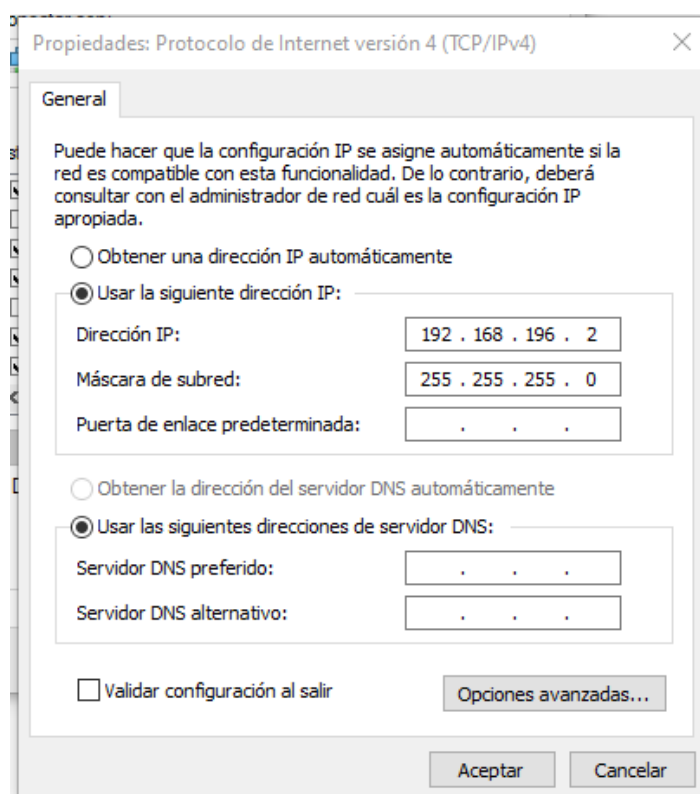


Ilustración 4. Configuración VMnet8 host anfitrión

Una vez finalizado el proceso de instalación aparece el panel principal donde se encuentran las diferentes acciones que se pueden realizar, tal y como se muestra en la ilustración 5. En este caso se modifican las direcciones IPs asignando en la WAN la red 192.168.0.152/24 y en la LAN la red 192.168.29.1. En la ilustración 5 es el resultado final de como quedan las redes.

```
FreeBSD/amd64 (pfSense.home.arpa) (ttyv0)

VMware Virtual Machine - Netgate Device ID: 356959119a206e6b3fbd

*** Welcome to pfSense 2.6.0-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.0.152/24
LAN (lan)      -> em1      -> v4: 192.168.29.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Disable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell
```

Ilustración 5. Configuración red PfSense

El siguiente paso es acceder al panel de administración vía web y terminar con la configuración. Al acceder aparece una guía rápida de configuración donde se habilita el DHCP para la WAN y la red LAN se queda en estático.

Por otro lado, como se observa en la ilustración 6, se dejan habilitadas las reglas “Block private networks from entering via WAN” que bloquea todo el tráfico que venga de internet con IPs privadas. Y la otra regla es “Block non-Internet routed networks from entering via WAN” que bloquea todo el tráfico de IPs que están reservadas y que no deberían aparecer en ninguno de los paquetes que se recibe [10].

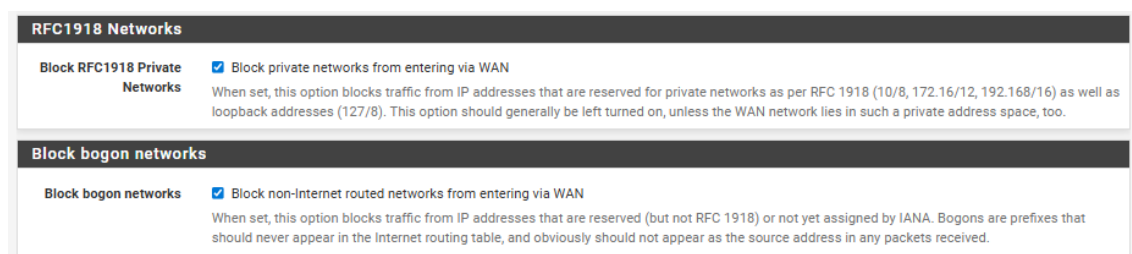


Ilustración 6. Reglas por defecto PfSense

4.1.1 Creación reglas PFsense

Una vez finalizado el proceso de instalación y configuración de PFsense se procede a crear las reglas necesarias para garantizar la seguridad y el correcto funcionamiento de la infraestructura.

Por un lado, tenemos las reglas de la interfaz WAN:

- Permitir comunicaciones desde el host anfitrión: se permite el tráfico proveniente de la dirección 192.168.0.99 hacia la red LAN. De esta forma, únicamente el host principal podrá establecer conexiones con las máquinas virtuales como Wazuh ya que esto es necesario para la monitorización.
- Restricción de Accesos a servicios de administración: se bloquean las conexiones entrantes por los puertos 443 (HTTPS) y 80 (HTTP) desde la WAN hacia los paneles de administración de Wazuh, QRadar y PFsense. Con ello se evita la administración remota no autorizada de los diferentes componentes. Por ello es necesario la regla anterior, para no bloquear el acceso desde el host anfitrión.

Floating

WAN

LAN

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	0 / 397 KiB	*	RFC 1918 networks	*	*	*	*	*		Block private networks	
☒	0 / 94 KiB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	
☐	0 / 0 B	IPv4 TCP	192.168.0.99	*	LAN net	*	*	none		Permite acceso desde anfitrión a LAN	
☐	0 / 0 B	IPv4 TCP	WAN net	*	LAN net	*	*	none			

Ilustración 7. Configuración reglas WAN

Reglas de red LAN, en este caso se mantiene las reglas predeterminadas:

- Anti lockout rule: evita el bloqueo involuntario del acceso a la consola de administración del firewall
- Default allow LAN to any rule: permite todo el tráfico de la red LAN a cualquier puerto y destino, así no interfiere en la comunicación de las máquinas para las integraciones que se van a realizar.
- Default allow LAN IPv6 to any rule: lo mismo que lo anterior, pero con IPv6. En este caso se deja ya que está por defecto, pero no aplica porque no se usa IPv6.

No se han añadido reglas adicionales en la LAN, ya que se ha considerado apropiado mantener libre la comunicación interna entre las máquinas virtuales. El control de accesos se centraliza en la interfaz WAN, de modo que únicamente se autoricen aquellas conexiones estrictamente necesarias para el correcto funcionamiento de los sistemas desplegados en la red.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	2 / 10.20 MIB	*	*	*	LAN Address	80 22	*	*		Anti-Lockout Rule	
☐	555 / 140.31 MIB	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN to any rule	
☐	0 / 0 B	IPv6 *	LAN net	*	*	*	*	none		Default allow LAN IPv6 to any rule	

Ilustración 8. Configuración reglas LAN

4.2 Instalación y configuración QRadar

Para la instalación de QRadar se hace a través de un fichero “ova”, que se descarga desde la propia web de IBM, el proveedor de esta herramienta [11]. Este tipo de fichero consiste en una máquina virtual empaquetada, que contiene archivos e información, es decir, no es una máquina “limpia”. El siguiente paso es ejecutar el *script* “/opt/ibm/cloud/qradarce_setup.sh” [12], se trata de un proceso automatizado y no requiere de muchos pasos para poder tenerlo instalado. Una vez finalizado la ejecución del *script* se inicia el servicio “httpd”, que pertenece al protocolo HTTP con el que accedemos vía web a la administración de QRadar. También se inicia el servicio “ssh” para la administración a través de la consola ya que algunas configuraciones solo se pueden hacer a través de esta. Se realiza a través de SSH con la aplicación mobaXterm, por comodidad en el formato de la consola. También es necesario levantar el proceso de tomcat que es donde se encuentra la interfaz web, que se accede por el navegador.

Se detecta que cada vez que se apaga la máquina QRadar, es necesario volver a levantar el servicio “httpd” ya que este no se mantiene activo. En cambio, el servicio “ssh” solo levanta la primera vez y se conversa en el mismo estado tras reiniciar la máquina.

4.2.1 Problemas encontrados

En el siguiente punto se va a comentar los problemas que han surgido durante la configuración de QRadar. Principalmente uno de los problemas que se ha encontrado es con la ventana de “log activity”, donde se puede acceder para ver los eventos, aparecía un error al conectar con el servidor de consultas. En la ilustración 9 se refleja el error.

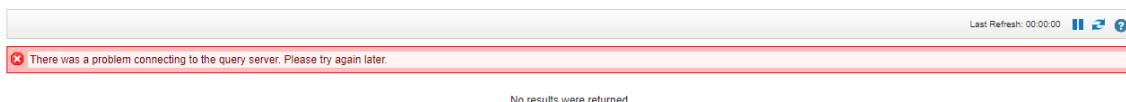


Ilustración 9. Error log activity

Para realizar consultas existe el servicio “ariel_proxy_server”, que se encarga de realizar las consultas a la base de datos Ariel, donde se almacenan todos los eventos. A través del terminal se verifica el estado, se muestra en la ilustración 10, y se observa que ha terminado el servicio (code=exited) y el estado da un error 255.

```
[root@localhost ~]# systemctl status ariel_proxy_server.service
● ariel_proxy_server.service - Ariel Proxy Server
   Loaded: loaded (/usr/lib/systemd/system/ariel_proxy_server.service; static; vendor preset: disabled)
   Active: failed (Result: exit-code) since Wed 2024-06-26 22:34:22 UTC; 33min ago
     Process: 7648 ExecStartPre=/opt/qradar/systemd/bin/generate_environment.sh ariel_proxy_server ariel_proxy (code=exited, status=255)
     Process: 7517 ExecStartPre=/opt/qradar/systemd/bin/console_check.sh (code=exited, status=0/SUCCESS)

Jun 26 22:34:20 localhost.localdomain systemd[1]: Starting Ariel Proxy Server...
Jun 26 22:34:22 localhost.localdomain ariel_proxy_server[7648]: ariel_proxy_server has been manually stopped.
Jun 26 22:34:22 localhost.localdomain systemd[1]: ariel_proxy_server.service: control process exited, code=exited status=255
Jun 26 22:34:22 localhost.localdomain systemd[1]: Failed to start Ariel Proxy Server.
Jun 26 22:34:22 localhost.localdomain systemd[1]: Unit ariel_proxy_server.service entered failed state.
Jun 26 22:34:22 localhost.localdomain systemd[1]: ariel_proxy_server.service failed.
[root@localhost ~]# systemctl restart ariel_proxy_server
Job for ariel_proxy_server.service failed because the control process exited with error code. See "systemctl status ariel_proxy_server.service" and "journalctl -xe" for details.
```

Ilustración 10. Error servicio Ariel

Se accede a la web de soporte de IBM para solucionar el error, y se localiza una página que explicar cómo verificar el error y la solución para un problema similar. Los pasos son los siguientes:

1. Se reinicia el servicio con el comando:

```
systemctl restart ariel_proxy_server
```

2. Se accede a los logs de la ruta “/var/log/qradar.log” y se encuentra el siguiente mensaje:

```
[root@localhost ~]# tail -f /var/log/qradar.log | grep ariel_proxy
Jun 26 23:09:13 localhost ariel_proxy_server[5988]: ariel_proxy_server has been manually stopped.
```

Ilustración 11. Error qradar.log

3. En la web de soporte de IBM aparece otro error distinto al de este problema.

Al verificar que el problema se debe a otra causa, se busca de nuevo en la web de soporte de IBM. Tras la búsqueda se encuentra otra página donde se indica que en la versión 7.3.3 o 7.4.4 *Community Edition*, existe un *bug* debido a la función de licencia del producto, que provoca que no funcione el “log activity”. La solución es ejecutar el siguiente comando a través del terminal [24].

```
if [ -f /opt/qradar/ecs/license.txt ] ; then echo -n "QRadar:Q1
Labs      Inc.:0007634bdale2:WnT9X7BDF0gB1WaXwokODc:12/31/20" >
/opt/qradar/ecs/license.txt ; fi ; if [ -f
/opt/ibm/si/services/ecs-ec-
ingress/current/eventgnosis/license.txt ] ; then echo -n
"QRadar:Q1 Labs
Inc.:0007634bdale2:WnT9X7BDF0gB1WaXwokODc:12/31/20" >
/opt/ibm/si/services/ecs-ec-
ingress/current/eventgnosis/license.txt ; fi ; if [ -f
/opt/ibm/si/services/ecs-ep/current/eventgnosis/license.txt ] ;
then echo -n "QRadar:Q1 Labs
Inc.:0007634bdale2:WnT9X7BDF0gB1WaXwokODc:12/31/20" >
/opt/ibm/si/services/ecs-ep/current/eventgnosis/license.txt ;
fi ; if [ -f /opt/ibm/si/services/ecs-
ec/current/eventgnosis/license.txt ] ; then echo -n "QRadar:Q1
Labs      Inc.:0007634bdale2:WnT9X7BDF0gB1WaXwokODc:12/31/20" >
/opt/ibm/si/services/ecs-ec/current/eventgnosis/license.txt ;
fi ; if [ -f /usr/eventgnosis/ecs/license.txt ] ; then echo -n
"QRadar:Q1 Labs
Inc.:0007634bdale2:WnT9X7BDF0gB1WaXwokODc:12/31/20" >
/usr/eventgnosis/ecs/license.txt ; fi ; if [ -f
/opt/qradar/conf/templates/ecs_license.txt ] ; then echo -n
"QRadar:Q1 Labs
Inc.:0007634bdale2:WnT9X7BDF0gB1WaXwokODc:12/31/20" >
/opt/qradar/conf/templates/ecs_license.txt ; fi
```

Una vez finalizado, se revisa que se ha solucionado el problema ya se pueden realizar consultas a la base de datos.

También aparecía una ventana con el error que aparece en la ilustración 12.

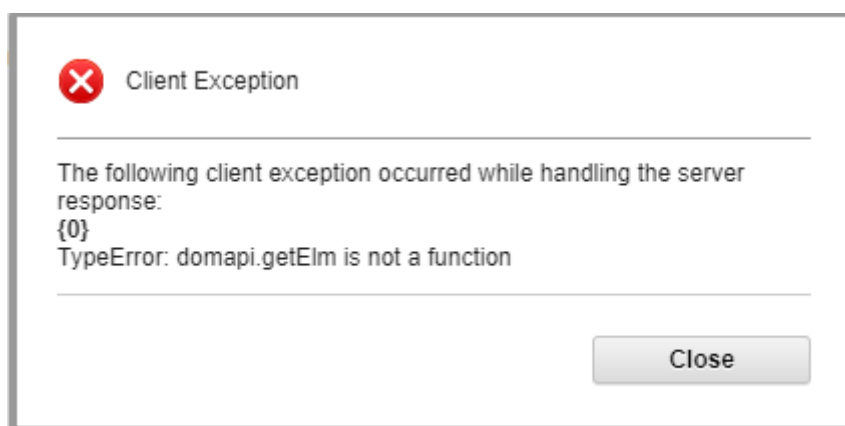


Ilustración 12. Error QRadar

Tras realizar una búsqueda en la web IBM se encuentra que es por la versión del navegador. Esto se debe a que la versión de Firefox es la 68.0.1 y debería ser la versión 71.0 en Windows 10. Se soluciona actualizando el navegador [13].

4.3 Instalación y configuración Wazuh

Para la instalación y configuración de Wazuh, se divide en dos partes, siendo la primera la instalación del servidor Wazuh y después la configuración del agente Wazuh. En los dos siguientes puntos se va a detallar el proceso para la instalación e integración entre ambos.

4.3.1 Instalación y configuración Wazuh server

Se descarga desde la propia web de Wazuh un fichero OVA, que se trata de una máquina que ya contiene Wazuh server. Una vez instalada ya se encuentra operativa para añadir los agentes que se van a monitorizar. Hay que comprobar que todos los servicios que componen Wazuh server estén activos. Los servicios son los siguientes:

- Wazuh-dashboard: Es la interfaz gráfica de usuario que permite visualizar los eventos de seguridad, gestionar alertas y monitorear el estado de los agentes y del sistema [14].
- Wazuh-indexer: Se encarga de almacenar, indexar y buscar logs recolectados por los agentes y otros sistemas, optimizando la velocidad de consulta y análisis de grandes volúmenes de datos. [14]
- Filebeat: Es un agente ligero de envío de logs, que captura eventos desde archivos de registro del sistema o aplicaciones y los envía al Wazuh-manager o al indexador para su procesamiento. [14]

- Wazuh-manager: Es el núcleo de Wazuh, responsable de recibir datos de los agentes, analizarlos, generar alertas y distribuir las reglas de detección a los agentes conectados. [14]

4.3.2 Instalación y configuración agente Wazuh

El agente Wazuh se puede instalar en múltiples equipos y todos estos serán administrados desde Wazuh server. Para este caso se va a instalar solo en una máquina virtual ya que el entorno es limitado y no es posible tener grandes cantidades de eventos. También por QRadar que, al ser una versión gratuita, como se ha comentado anteriormente, tiene limitaciones y no permite grandes volúmenes de eventos. Por tanto, solo se va a monitorizar en equipo y este es el propio host anfitrión con un sistema operativo Windows 10.

A través de la web de wazuh (se accede con <https://192.168.29.130>) desde el botón "Deploy new agent". A continuación, aparece una ventana donde se aparece el sistema operativo, la IP de servidor Wazuh y el nombre del agente. Entonces aparece un comando que hay que ejecutar en PowerShell en el agente a instalar [15]. El comando es el siguiente:

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.4.5-1.msi -OutFile ${env:tmp}\wazuh-agent.msi; msixexec.exe /i ${env:tmp}\wazuh-agent.msi /q WAZUH_MANAGER='192.168.29.130' WAZUH_REGISTRATION_SERVER='192.168.29.130' WAZUH_AGENT_NAME='Cliente-win'
```

Posteriormente se inicia el servicio de Wazuh en el agente.

```
NET START WazuhSvc
```

En la ilustración 13 ya aparece el agente como conectado.

ID ↑	Name	IP address	Group(s)	Operating system	Cluster node	Version	Status	Actions
005	DESKTOP-5PDE42L	192.168.0.99	default	 Microsoft Windows 10 Home 10.0.19045.6216	node01	v4.4.5	● active	 

Ilustración 13. Agente conectado

4.4 Instalación y configuración Suricata

Se crea una máquina virtual con el sistema operativo Ubuntu Server, y en esta se instala suricata. Tras la instalación es necesario realizar la configuración para que la máquina sea capaz de monitorizar la red. Para esto hay que modificar el fichero “/etc/suricata/suricata.yaml” [16]. Este se divide en cuatro pasos que hay que cambiar y que se comentarán a continuación.

En el primer paso es la variable “HOME_NET”, que indica que considerará como redes locales y en este caso se escogen todas las IPs privadas.

```
# Suricata configuration file. In addition to the comments describing all
# options in this file, full documentation can be found at:
# https://redmine.openinfosecfoundation.org/projects/suricata/wiki/Suricatayaml
##
## Step 1: inform Suricata about your network
##
vars:
  # more specific is better for alert accuracy and performance
  address-groups:
    HOME_NET: "[192.168.0.0/16,10.0.0.0/8,172.16.0.0/12]"
    #HOME_NET: "[192.168.0.0/16]"
    #HOME_NET: "[10.0.0.0/8]"
    #HOME_NET: "[172.16.0.0/12]"
    #HOME_NET: "any"
```

Ilustración 14. Configuración suricata paso 1

El segundo paso se configura los logs de salida en que ruta y ficheros se van a guardar. En este caso se deja la ruta por defecto.

```
##
## Step 3: select outputs to enable
##
# The default logging directory. Any log or output file will be
# placed here if its not specified with a full path name. This can be
# overridden with the -l command line parameter.
default-log-dir: /var/log/suricata/
```

Ilustración 15. Configuración suricata paso 2

El tercer paso se configura la interfaz de red donde se capturan los paquetes para la monitorización. Como se observa en ilustración 16 es la interfaz ens33, que es donde va a estar escuchando todo el tráfico.

```
##
## Step 4: configure common capture settings
##
## See "Advanced Capture Options" below for more options, including NETMAP
## and PF_RING.
##

# Linux high speed capture support
af-packet:
  - interface: ens33
```

Ilustración 16. Configuración suricata paso 3

Por último, en el cuarto paso se configura los analizadores de la capa de aplicación en Suricata. Así se especifica como debe comportarse suricata frente a distintos protocolos y cómo manejar los errores que pueden surgir. Se dejan habilitados ya que esto optimiza la precisión del sistema a la hora de monitorizar la red.

```
# The protocol's section details each protocol.
#
# The option "enabled" takes 3 values - "yes", "no", "detection-only".
# "yes" enables both detection and the parser, "no" disables both, and
# "detection-only" enables protocol detection only (parser disabled).
app-layer:
  # error-policy: ignore
  protocols:
    telnet:
      enabled: yes
    rfb:
      enabled: yes
      detection-ports:
        dp: 5900, 5901, 5902, 5903, 5904, 5905, 5906, 5907, 5908, 5909
    mqtt:
      enabled: yes
      # max-msg-length: 1mb
      # subscribe-topic-match-limit: 100
      # unsubscribe-topic-match-limit: 100
      # Maximum number of live MQTT transactions per flow
      # max-tx: 4096
    krb5:
      enabled: yes
    bittorrent-dht:
      enabled: yes
    snmp:
      enabled: yes
    ike:
      enabled: yes
    tls:
      enabled: yes
      detection-ports:
        dp: 443
```

Ilustración 17. Configuración suricata paso 4

Finalmente se reinicia suricata para que se apliquen los cambios.

4.4.1 Reglas Suricata

En Suricata existen reglas creadas por defecto que se encuentran en la ruta “/var/lib/suricata/rules” y fichero se llama “suricata.rules”. Se decide crear, además de las reglas predeterminadas, reglas personalizadas, y así que sean de mayor precisión para el entorno específico de la red que se desea proteger. Además, las reglas personalizadas pueden adaptarse rápidamente a nuevas amenazas o cambios en la infraestructura de red, proporcionando una capa adicional de seguridad adaptativa y específica para los requisitos del entorno.

Para poder realizarlo se crea el fichero “/etc/suricata/rules/custom.rules” y se añade a la ruta que utiliza suricata para hacer uso de las reglas, en el fichero suricata.yaml, como se observa en la ilustración 18.

```
##
## Step 2: select the rules to enable or disable
##

default-rule-path: /etc/suricata/rules
rule-files:
- custom.rules
- decoder-events.rules # available in suricata sources under rules dir
- stream-events.rules # available in suricata sources under rules dir
- http-events.rules # available in suricata sources under rules dir
- smtp-events.rules # available in suricata sources under rules dir
- dns-events.rules # available in suricata sources under rules dir
- tls-events.rules # available in suricata sources under rules dir
```

Ilustración 18. Ruta fichero reglas Suricata

A continuación, se van a detallar las reglas que se han creado para detectar la actividad anómala y posibles riesgos, que interesa identificar en el entorno donde se encuentra el NIDS [20].

- Múltiples intentos de conexión SSH: Detecta intentos repetidos de conexión al puerto 22 (SSH) desde la misma IP en un período corto (5 intentos en 60 segundos). Esto permite identificar posibles ataques de fuerza bruta.

```
alert tcp any any -> any 22 (msg:"Multiples intentos de conexion SSH"; flags:S;
threshold:type both, track by_src, count 5, seconds 60; sid:1000001; rev:1;)
```

- Acceso HTTP no autorizado: Genera una alerta ante cualquier conexión al puerto 80 que no esté permitida por las políticas. Sirve para identificar accesos web no autorizados a servidores HTTP.

```
alert tcp any any -> any 80 (msg:"Acceso HTTP no autorizado"; sid:1000005;
rev:1;)
```

- HTTP contiene "admin": Detecta cuando el cuerpo de una solicitud HTTP contiene la palabra "admin". Esto puede evidenciar intentos de acceso a rutas administrativas o directorios sensibles en un sitio web.

```
alert tcp any any -> any 80 (msg:"HTTP contiene 'admin'"; content:"admin";
http_client_body; sid:1000006; rev:1;)
```

- HTTP User-Agent contiene curl: Detecta solicitudes HTTP cuyo User-Agent contiene "curl". Esto suele indicar que un usuario o script está accediendo al servidor mediante herramientas de línea de comandos en lugar de un navegador, lo cual puede ser signo de pruebas o ataques automatizados.

```
alert tcp any any -> any 80 (msg:"HTTP User-Agent contiene curl";
content:"curl"; http_header; sid:1000007; rev:1;)
```

- Descarga de EXE detectada: Alerta cuando la URI de una solicitud HTTP contiene archivos con extensión .exe. Es útil para detectar intentos de descarga de ejecutables, que pueden representar malware o descargas no autorizadas.

```
alert tcp any any -> any 80 (msg:"Descarga de EXE detectada"; content:".exe";
http_uri; nocase; sid:1000009; rev:1;)
```

En el punto 6 pruebas, se realizan comprobaciones para ver que funciona correctamente y generan alertas.

5 Integraciones

En el siguiente apartado se va a detallar el procedimiento que se ha llevado a cabo para la integración de las diferentes fuentes en QRadar, tanto en la parte de la propia fuente como la que se realiza en QRadar.

Antes de empezar a describir como se ha realizado las integraciones, se va a explicar como es el funcionamiento de la recepción de eventos en QRadar. De esta forma, se podrán entender los conceptos que se utilizarán a lo largo de los siguientes puntos.

Existen diferentes formas para que QRadar reciba los eventos se puede configurar a través de Syslog o API, para estas fuentes se va a hacer a través de syslog. Una vez llegan los eventos estos son parseados y normalizados, que se encarga de realizarlo para ser clasificados y correlacionados, y luego almacenados en su base de datos. [17]

Para realizar esta normalización, QRadar utiliza los Device Support Modules (DSM). Un DSM es un módulo específico que contiene las reglas y patrones necesarios para interpretar correctamente los eventos generados por un tipo concreto de dispositivo. Cada DSM traduce los eventos de una fuente a un formato estándar en QRadar, permitiendo que sean comprendidos, categorizados y procesados de manera uniforme, independientemente del origen del evento. Esto es fundamental para que la correlación y las reglas de seguridad funcionen de forma efectiva en toda la infraestructura monitorizada [18].

Por otro lado, esta la fuente que por cada uno de los dispositivos que se instalen se crea una fuente distinta. Esto es para dividir los eventos y poder categorizarlos según el origen de donde vienen. Esto posteriormente se utiliza para crear reglas [19].

5.1 Integración Wazuh

Para la integración de Wazuh en QRadar es necesario realizar previamente la configuración del archivo `/var/ossec/etc/ossec.conf` en el servidor de Wazuh. En este fichero se debe especificar el destino al cual serán enviados los eventos mediante Syslog, como se presenta en la ilustración 19.

En particular, dentro de la sección correspondiente se añade la dirección IP del servidor de QRadar, que en este caso es 192.168.29.131. Esta configuración permite que todos los eventos generados y gestionados por Wazuh sean transmitidos de forma automática hacia QRadar para su posterior análisis, normalización y correlación [21].

```
<syslog_output>
  <server>192.168.196.209</server>
  <port>514</port>
  <level>3</level>
  <format>json</format>
</syslog_output>
```

Ilustración 19. Habilitar syslog de Wazuh a QRadar

El siguiente paso es crear en QRadar el DSM de Wazuh ya que este no existe, en la ilustración 20 aparece la ventana que se crea la fuente.

Select Log Source Type

Choose an existing Log Source Type to modify, or create a new Log Source Type

Log Source Type Name

Wazuh

Save Go Back

Ilustración 20. DSM Wazuh

Una vez disponible el DSM correspondiente, se procede en QRadar a la creación de la fuente de eventos, tal y como se muestra en la ilustración 21. En este apartado se definen los parámetros básicos de configuración: el nombre de la fuente, el tipo de fuente, que en este caso corresponde a Wazuh (previamente creado mediante el DSM), y el protocolo de recepción, que será Syslog. El resto de los parámetros se mantienen con los valores predeterminados.

Log Source Name	Wazuh
Log Source Description	Wazuh
Log Source Type	Wazuh
Protocol Configuration	Syslog (Undocumented) ▼
Log Source Identifier	wazuh-server
Enabled	☒
Credibility	5 ▼
Target Event Collector	eventcollector0 :: localhost ▼
Coalescing Events	☒
Incoming Payload Encoding	UTF-8 ▼
Store Event Payload	☒
Log Source Extension	WazuhCustom_ext ▼

Ilustración 21. Creación log source Wazuh

Como el DSM de la fuente no estaba creado, una vez recibidos los logs fue necesario definir los campos que permiten identificar el tipo de evento. Para ello, primero se configuraron los “eventID” y “eventCategory”, a partir de los cuales se generaron los “eventName”, que representan el nombre asociado a cada evento. Para poder identificarlos se utiliza expresiones regulares como puede verse en la ilustración 22. En ese caso se está cogiendo el número 5061 como parte del identificador del nombre del evento. En la ilustración 23 se muestra la expresión regular del “eventCategory”, que es el tipo de categoría en el que se encuentra el evento. En este caso es “ossec” que es en lo que esta basado wazuh.

The screenshot shows the Wazuh configuration interface. On the left, the 'Event ID' is set to 'event'. The 'Property Configuration' section has 'Override system behavior' checked. The 'Expressions' section shows a single expression: 'eventID\":\"(d+)\", with a format string of '\$1'. The 'Wrap Content' checkbox is checked. The log data on the right shows a Windows audit failure event with 'eventID': '5061' highlighted in green.

Ilustración 22. Mapeo eventID

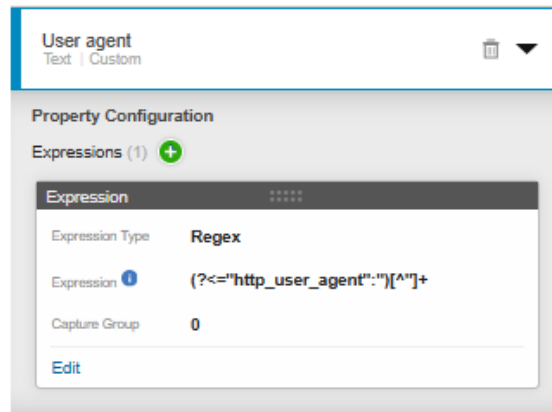


Ilustración 26. Campo user agent

5.2 Integración Suricata

Para la integración de Suricata en QRadar en la propia web de IBM existe un manual para realizarla, que es el que se utiliza para llevarlo a cabo. Para ello, se necesita modificar el fichero la entrada “eve-log” del fichero “suricata.yaml”. En concreto se modifica la variable “facility”, que se refiere a una categoría de mensajes de *log* que permite clasificar y gestionar adecuadamente los mensajes enviados a un sistema de syslog [22].

```
- eve-log:
  enabled: yes
  filetype: syslog #regular|syslog|unix_dgram|unix_stream|redis
  identity: "suricata"
  facility: local5
  filename: eve.json
```

Ilustración 27. Integración QRadar de Suricata

Después se modifica el fichero “/etc/rsyslog.conf”, añadiendo la configuración syslog para poder reenviar los eventos a QRadar. Con esto se realiza que todos los *logs* generados con la “facilidad local5” se reenvíen por TCP al servidor de logs ubicado en 192.168.29.131:514 [22].

```
#Configuracion syslog Qradar
local5.* @192.168.29.131:514
```

Ilustración 28. Syslog para integración de Suricata

Por último, se reinician los servicios de suricata y Rsyslog para que los cambios se hagan efectivos.

En este caso no es necesario crear DSM, como en el punto anterior, ya que QRadar lo proporciona. Sin embargo, no viene directamente en QRadar hay que descargarlo de la web de IBM e instalarlo como una aplicación. Una vez instalado los eventos vienen identificados correctamente.

5.3 Integración pfSense

Para PFsense se accede al panel de administración y en el menú “status -> System logs -> settings” en el “remote logging options” se habilita y se configura al destino que se va a enviar. También se selecciona los eventos que se envíen. En este caso las opciones elegidas son:

- Firewall eventos:
- DNS events.
- DHCP events

La elección de estas opciones se justifica porque corresponden a los eventos más relevantes para el análisis de seguridad y de red. Los registros de firewall permiten identificar intentos de acceso no autorizados, los de DNS ayudan a detectar resoluciones de nombres potencialmente maliciosos, y los de DHCP facilitan la trazabilidad de dispositivos dentro de la red. Asimismo, dado que QRadar tiene una capacidad máxima de procesamiento de eventos, resulta necesario priorizar únicamente aquellos que aportan mayor valor en términos de seguridad y monitorización.

Remote Logging Options

Enable Remote Logging

☒ Send log messages to remote syslog server

Source Address

Default (any)

This option will allow the logging daemon to bind to a single IP address, rather than all IP addresses. If a single IP is picked, remote syslog servers must all be of that IP type. To mix IPv4 and IPv6 remote syslog servers, bind to all interfaces.

NOTE: If an IP address cannot be located on the chosen interface, the daemon will bind to all addresses.

IP Protocol

IPv4

This option is only used when a non-default address is chosen as the source above. This option only expresses a preference; If an IP address of the selected type is not found on the chosen interface, the other type will be tried.

Remote log servers

192.168.29.131:514

IP[:port]

IP[:port]

Remote Syslog Contents

☐ Everything
☒ System Events
☒ Firewall Events
☒ DNS Events (Resolver/unbound, Forwarder/dnsmasq, filterdns)
☒ DHCP Events (DHCP Daemon, DHCP Relay, DHCP Client)
☐ PPP Events (PPPoE WAN Client, L2TP WAN Client, PPTP WAN Client)
☐ General Authentication Events
☐ Captive Portal Events
☐ VPN Events (IPsec, OpenVPN, L2TP, PPPoE Server)
☐ Gateway Monitor Events
☐ Routing Daemon Events (RADVD, UPnP, RIP, OSPF, BGP)
☐ Network Time Protocol Events (NTP Daemon, NTP Client)
☐ Wireless Events (hostapd)

Syslog sends UDP datagrams to port 514 on the specified remote syslog server, unless another port is specified. Be sure to set syslogd on the remote server to accept syslog messages from pfSense.

Ilustración 29. Configuración syslog pfsense

Como en el caso de suricata, los eventos llegaban a la fuente “SIM Generic”, que es donde se meten los eventos que no están vinculados a ninguna fuente. En la ilustración 30 se observa que los eventos llegan como “unknown log event”. Sin embargo, también se tiene un DSM de IBM que se descarga e instala y ya llegan los eventos como corresponde.

Event Name	Log Source	Even: Coun	Time ▼	Low Level Category	Source IP	Source Port	Destination IP	Destina Port
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:13:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:13:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:12:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:12:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:11:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:11:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:10:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:10:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:09:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:09:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:08:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:08:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:07:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:07:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:06:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:06:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:05:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:05:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:04:3...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0
Unknown log event	SIM Generic Log DSM-7 :: loc...	1	Aug 21, 2025, 3:04:0...	Unknown Generic Log Event	192.168.29.1	0	192.168.29.1	0

Ilustración 30. Eventos unknown pfsense



Una vez instalada como aparece en la ilustración 31, se habilita la autodetección y así automáticamente QRadar añade la fuente a su correspondiente tipo.

Extensions Management

IBM Security App Exchange

Search by extension name

ALL ITEMS

INSTALLED

NOT INSTALLED

Add

Name	Status	Author	Added On
PfSenseDSM.txt-ContentExport-20190606174705.xml No description Install Delete (More Details...)	Not Installed	admin	August 22, 2025
QRadar Assistant App	Installed	IBM QRadar	August 17, 2025

Ilustración 31. Instalación DSM pfsense

Log Source Type

pfSense

Change

Properties

Event Mappings

Configuration

Log Source Autodetection Configuration

Enable Log Source Autodetection

When events from an unknown source are received, attempt to parse them with this log source type. If the parsing is sufficiently successful, automatically create a log source of this type.

✓

Ilustración 32. Autodetección habilitada

6 Pruebas

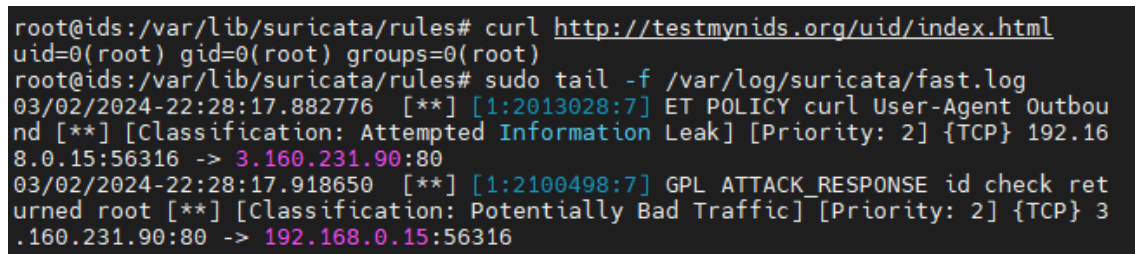
Una vez desplegadas las máquinas e integradas en QRadar, se realizaron diversas pruebas con el objetivo de verificar la correcta generación de alertas tanto en Suricata como en Wazuh. Asimismo, se comprobó que los eventos recibidos por QRadar son procesados y dan lugar a la creación de ofensas (término utilizado en QRadar para las alertas de seguridad), generadas a partir de las reglas previamente definidas en la plataforma. Para determinados casos específicos, las pruebas se complementaron utilizando la máquina Kali Linux, con el fin de simular escenarios de ataque y evaluar la capacidad de detección del sistema.

6.1 Pruebas Suricata

En la web de suricata se detalla una prueba para comprobar que funciona correctamente. Se trata de un conjunto de reglas “ET Open”, escrita específicamente para casos de prueba. Para ello se ejecuta el siguiente comando [23].

```
curl http://testmynids.org/uid/index.html
```

Se accede al archivo “/var/log/suricata/fast.log y se encuentra los logs relacionados con la alerta.



```
root@ids:/var/lib/suricata/rules# curl http://testmynids.org/uid/index.html
uid=0(root) gid=0(root) groups=0(root)
root@ids:/var/lib/suricata/rules# sudo tail -f /var/log/suricata/fast.log
03/02/2024-22:28:17.882776  [**] [1:2013028:7] ET POLICY curl User-Agent Outbound [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.0.15:56316 -> 3.160.231.90:80
03/02/2024-22:28:17.918650  [**] [1:2100498:7] GPL ATTACK_RESPONSE id check returned root [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 3.160.231.90:80 -> 192.168.0.15:56316
```

Ilustración 33. Log suricata

Para probar el documento de reglas personalizadas, se crea una regla de prueba donde se detecta que desde un activo se realiza un *ping* hacia otro activo. La regla quedaría como se aparece a continuación.

```
alert icmp any any -> any any (msg: "ICMP packet found"; sid:2000001; rev:1;)
```

Para activar la regla desde la máquina donde se encuentra QRadar se hace un *ping* a la máquina que contiene Suricata. Al revisar los logs se comprueba que se ha recibido un evento, que ha sido generado por esta regla. El evento recibido en suricata se encuentra en la ilustración 34.

```
08/23/2025-01:03:38.627246 [**] [1:200001:1] ICMP Packet found [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.1:3 -> 192.168.29.132:1
08/23/2025-01:03:38.628129 [**] [1:200001:1] ICMP Packet found [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.1:3 -> 192.168.29.132:1
08/23/2025-01:03:38.629006 [**] [1:200001:1] ICMP Packet found [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.1:3 -> 192.168.29.132:1
```

Ilustración 34. Evento generado regla suricata en QRadar

En este punto ya se encuentra integrado Suricata con QRadar, y como se presenta en la ilustración 35, el evento también ha llegado al SIEM.

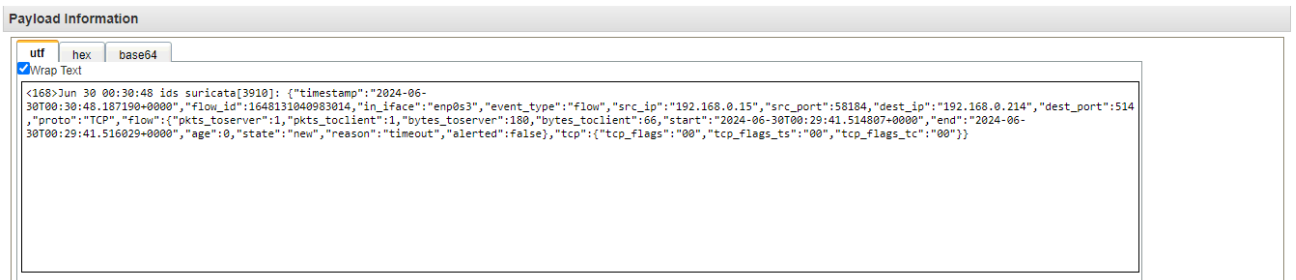


Ilustración 35. Evento generado regla suricata en QRadar

Una vez se comprueba que se generan correctamente las alertas y llegan los eventos a QRadar. Se elimina la regla de prueba y se crean las reglas que se utilizarán posteriormente. Estas están detalladas en el punto 4.4.1. Para verificar que están creadas correctamente se crea un script en Kali Linux., donde se generan cinco pruebas para cada una de las reglas. Este script se explica y muestra a continuación.

```
#!/bin/bash
```

```
# Pruebas para reglas Suricata
```

```
SERVER="192.168.29.1" # IP del servidor que se va a monitorizar
```

Esta prueba simula un ataque de fuerza bruta en SSH (puerto 22) y es para la regla de múltiples intentos SSH. Esta se genera si se hacen cinco intentos en menos de un minuto. Entonces con el comando nc (netcat), que se utiliza para hacer conexiones a cualquier puerto e IP que se indique, se realizan seis intentos de conexión en menos de un minuto.

```
echo "[*] Prueba 1: Múltiples intentos SSH (5 en 60s)"
```

```
for i in {1..6}; do nc -vz $SERVER 22; doneE
```

Aquí se hace una petición HTTP simple al servidor usando curl con la opción -I (solo cabeceras). La finalidad es comprobar que Suricata detecta tráfico web sin certificado SSL.

```
echo "[*] Prueba 2: Conexión HTTP (puerto 80)"
```

```
curl -I http://$SERVER/
```

En esta prueba se envían datos por POST a un formulario de login simulando credenciales. El valor "username=admin" busca activar la regla que detecta la cadena admin en el tráfico HTTP, lo que podría considerarse un intento de acceso con usuario comúnmente atacado.

```
echo "[*] Prueba 3: HTTP con cadena 'admin'"
```

```
curl -d "username=admin&password=test" http://$SERVER/login
```

Aquí se fuerza a que la petición HTTP incluya en la cabecera el User-Agent "curl". Detecta clientes poco habituales o automatizados, ya que pueden ser usados en ataques de escaneo o exfiltración de datos.

```
echo "[*] Prueba 4: HTTP con User-Agent curl"
```

```
curl -A "curl" http://$SERVER/
```

Finalmente, se simula la descarga de un archivo ejecutable (.exe) para la regla "Descarga de archivo .exe". Esta alerta sobre descargas de ejecutables, dado que este tipo de archivos suelen estar asociados a la distribución de malware.

```
echo "[*] Prueba 5: Descarga de archivo .exe"
```

```
curl -O http://$SERVER/test.exe
```

El resultado de la ejecución es que se han generado las alertas en Suricata, como se evidencia en la ilustración 36.

```
08/25/2025-04:56:28.540412  [**] [1:1000001:1] Múltiples intentos de conexión SSH [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:44808 -> 192.168.29.1:22
08/25/2025-04:56:28.575215  [**] [1:1000005:1] Acceso HTTP no autorizado [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45066 -> 192.168.29.1:80
08/25/2025-04:56:28.615681  [**] [1:1000007:1] HTTP User-Agent contiene curl [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45066 -> 192.168.29.1:80
08/25/2025-04:56:28.641263  [**] [1:1000005:1] Acceso HTTP no autorizado [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45070 -> 192.168.29.1:80
08/25/2025-04:56:28.708543  [**] [1:1000006:1] HTTP contiene 'admin' [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45070 -> 192.168.29.1:80
08/25/2025-04:56:28.708543  [**] [1:1000007:1] HTTP User-Agent contiene curl [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45070 -> 192.168.29.1:80
08/25/2025-04:56:28.735555  [**] [1:1000005:1] Acceso HTTP no autorizado [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45086 -> 192.168.29.1:80
08/25/2025-04:56:28.756273  [**] [1:1000007:1] HTTP User-Agent contiene curl [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45086 -> 192.168.29.1:80
08/25/2025-04:56:28.807575  [**] [1:1000005:1] Acceso HTTP no autorizado [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45094 -> 192.168.29.1:80
08/25/2025-04:56:28.819329  [**] [1:1000007:1] HTTP User-Agent contiene curl [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45094 -> 192.168.29.1:80
08/25/2025-04:56:28.819329  [**] [1:1000009:1] Descarga de EXE detectada [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.29.135:45094 -> 192.168.29.1:80
```

Ilustración 36. Alertas suricata

En la ilustración 37, se observa como llegan los eventos a QRadar.

Event Name	Source IP (Unique Count)	Destination IP (Unique Count)	Destination Port (Unique Count)	Log Source (Unique Count)	Low Level Category (Unique Count)	Protocol (Unique Count)
Acceso HTTP no autorizado	192.168.29.137	192.168.29.1	80	Suricata	HTTP Denied	tcp_ip
HTTP User-Agent contiene curl	192.168.29.137	192.168.29.1	80	Suricata	Suspicious Activity	tcp_ip
Múltiples intentos de conexión SSH	192.168.29.137	192.168.29.1	22	Suricata	Suspicious Activity	tcp_ip
Descarga de EXE detectada	192.168.29.137	192.168.29.1	80	Suricata	Misc Malware	tcp_ip
Peticion HTTP contiene admin	192.168.29.137	192.168.29.1	80	Suricata	Login with usernam...	tcp_ip

Ilustración 37. Alertas Suricata en QRadar

6.2 Pruebas pfsense

Durante la realización de las pruebas anteriores con Suricata, se verificó que pfSense aplicó correctamente las políticas internas, bloqueando la dirección IP desde la cual se simulaba el supuesto ciberataque. Esta acción puede ser confirmada mediante la revisión de los registros de eventos en QRadar.

```
<38>Aug 22 17:39:15 sshguard[13156]: Blocking "192.168.29.137/32" for 120 secs (3 attacks in 0 secs, after 1 abuses over 1 sec.)
<38>Aug 22 17:37:47 sshd[60250]: Did not receive identification string from 192.168.29.136 port 43550
<38>Aug 22 17:37:47 sshd[60034]: Did not receive identification string from 192.168.29.136 port 43538
<37>Aug 22 17:37:47 sshguard[13156]: Attack from "192.168.29.136" on service SSH with danger 10.
<38>Aug 22 17:37:47 sshd[59511]: Did not receive identification string from 192.168.29.136 port 43506
<38>Aug 22 16:29:00 sshguard[13156]: Now monitoring attacks.
<38>Aug 22 16:29:00 sshguard[98478]: Exiting on signal.
```

Ilustración 38. Registro pfsense en gradar

6.3 Pruebas Wazuh

Wazuh incluye reglas predeterminadas muy útiles para la detección de eventos en distintos sistemas operativos. En este caso nos enfocamos en equipos Windows, aunque también existen reglas específicas para Linux. Para verificar que el sistema de monitoreo funciona correctamente, se pueden realizar algunas pruebas controladas. Que se explicarán a continuación:

1. Se realiza intentos fallidos de autenticación, esto genera alerta en wazuh y posteriormente envía el log a QRadar como se comprueba en la ilustración 39.

[illegible]

Ilustración 39. Log logon failure



2. Se crea y elimina un usuario en Windows:

```
<132>Aug 26 05:13:44 wazuh-server ossec: {"timestamp":"2025-08-26T05:13:44.320+0000","rule":{"level":8,"description":"User account disabled or deleted.", "id":"60111","mitre":{"id":["T1098","T1531"],"tactic":["Persistence","Impact"],"technique":["Account Manipulation","Account Access Removal"]},"firedtimes":1,"mail":false,"groups":["windows","windows_security","account_changed","adduser"],"gdpr":["IV_32.2","IV_35.7.d"],"pgp13":["7.10"],"hipaa":["164.312.a.2.I","164.312.a.2.II","164.312.b"],"nist_800_53":["AC.2","AC.7","AU.14","IA.4"],"pci_dss":["10.2.5","8.1.2"],"tsc":["CC6.8","CC7.2","CC7.3"]},"agent":{"id":"001","name":"DESKTOP-5PDE42L","ip":"192.168.0.158"},"manager":{"name":"wazuh-server"},"id":"1756185224.2202933","decoder":{"name":"windows_eventchannel"},"data":{"win":{"system":{"providerName":"Microsoft-Windows-Security-Auditing","providerGuid":"{54849625-5478-4994-a5ba-3e3b0328c30d}","eventId":"4726","version":"0","level":"0","task":"13824","opcode":"0","keywords":"0x8020000000000000","systemTime":"202
```

Ilustración 40. Log user account delete

3. Se crea una clave de registro para ejecutar un problema automáticamente al iniciar sesión el usuario actual. La clave utilizada es "reg add \"HKCU\\Software\\Microsoft\\Windows\\CurrentVersion\\Run\" /v TestAutorun /t REG_SZ /d \"C:\\Windows\\System32\\notepad.exe\"". En la ilustración 41 se encuentra el log que se genero en QRadar.

```
<132>Aug 26 19:20:00 wazuh-server ossec: {"timestamp":"2025-08-26T19:20:00.816+0000","rule":{"level":3,"description":"Service startup type was changed.", "id":"61104","info":"This does not appear to be logged on Windows 2008","firedtimes":2,"mail":false,"groups":["windows","windows_system","policy_changed"],"pci_dss":["10.6"],"gdpr":["IV_35.7.d"],"hipaa":["164.312.b"],"nist_800_53":["AU.6"],"tsc":["CC6.1","CC6.8","CC7.2","CC7.3"]},"agent":{"id":"001","name":"DESKTOP-5PDE42L","ip":"192.168.0.99"},"manager":{"name":"wazuh-server"},"id":"1756236000.3135275","decoder":{"name":"windows_eventchannel"},"data":{"win":{"system":{"providerName":"Service Control Manager","providerGuid":"{555908d1-a6d7-4695-8e1e-26931d2012f4}","eventName":"Service Control Manager","eventId":"7040","version":"0","level":"4","task":"0","opcode":"0","keywords":"0x8080000000000000","systemTime":"2025-08-26T19:19:59.7503872Z","eventRecordID":"229086","processID":"896","threadID":"20952","channel":"System","computer":"DESKTOP-5PDE42L","sev
```

Ilustración 41. Log autorun

4. Por último, se elimina la clave de registro que anteriormente se ha creado "reg delete \"HKCU\\Software\\Microsoft\\Windows\\CurrentVersion\\Run\" /v TestAutorun /f". Se generan dos eventos uno de la creación, ilustración 42, y otro de la eliminación, ilustración 43.

```
<132>Aug 27 02:44:17 wazuh-server ossec: {"timestamp":"2025-08-27T02:44:17.576+0000","rule":{"level":5,"description":"Registry Key Integrity Checksum Changed.", "id":"594","mitre":{"id":["T1565.001","T1112"],"tactic":["Impact","Defense Evasion"],"technique":["Stored Data Manipulation","Modify Registry"]},"firedtimes":37,"mail":false,"groups":["ossec","syscheck","syscheck_entry_modified","syscheck_registry"],"pci_dss":["11.5"],"pgp13":["4.13"],"gdpr":["II_5.1.f"],"hipaa":["164.312.c.1","164.312.c.2"],"nist_800_53":["SI.7"],"tsc":["PI1.4","PI1.5","CC6.1","CC6.8","CC7.2","CC7.3"]},"agent":{"id":"001","name":"DESKTOP-5PDE42L","ip":"192.168.0.158"},"manager":{"name":"wazuh-server"},"id":"1756262657.404133","full_log":"Registry Key '[x64] HKEY_LOCAL_MACHINE\\Software\\Microsoft\\Active Setup\\Installed Components\\{8A69D345-D564-463c-AFF1-A69D9E530F96}' modified\\nMode: scheduled\\nChanged attributes: mtime\\nOld modification time was: '1756006315', now it is '1756252688'\\n","syscheck":{"path":"HKEY_LOCAL_MACHINE\\Softw
```

Ilustración 42. Log clave de registro añadida

```
<132>Aug 27 02:44:18 wazuh-server ossec: {"timestamp":"2025-08-27T02:44:18.910+0000","rule":{"level":5,"description":"Registry Value Entry Deleted.", "id":"751","mitre":{"id":["T1070.004","T1485","T1112"],"tactic":["Defense Evasion","Impact"],"technique":["File Deletion","Data Destruction","Modify Registry"]},"firedtimes":1,"mail":false,"groups":["ossec","syscheck","syscheck_entry_deleted","syscheck_registry"],"pci_dss":["11.5"],"pgp13":["4.13"],"gdpr":["II_5.1.f"],"hipaa":["164.312.c.1","164.312.c.2"],"nist_800_53":["SI.7"],"tsc":["PI1.4","PI1.5","CC6.1","CC6.8","CC7.2","CC7.3"]},"agent":{"id":"001","name":"DESKTOP-5PDE42L","ip":"192.168.0.158"},"manager":{"name":"wazuh-server"},"id":"1756262658.406693","full_log":"Registry Value '[x32] HKEY_LOCAL_MACHINE\\System\\CurrentControlSet\\Services\\SharedAccess\\Parameters\\FirewallPolicy\\FirewallRules\\{1E307A8A-B213-4353-982D-0182B830018}' deleted\\nMode: scheduled\\n","syscheck":{"path":"HKEY_LOCAL_MACHINE\\System\\CurrentControlSet\\Services\\SharedAccess\\Para
```

Ilustración 43. Log clave de registro eliminada

7 Monitorización

En esta sección se aborda el proceso de monitorización, cuyo objetivo es establecer mecanismos de detección y respuesta frente a eventos de seguridad una vez todas las fuentes están integradas. Así identificar comportamientos anómalos o potencialmente maliciosos en la red y en los sistemas monitorizados.

7.1 Reglas PFsense

Se han creado reglas específicas a partir del análisis de los registros que llegaban a QRadar, que se detalla en el punto 6.2. Como resultado, se configuraron las siguientes reglas:

- [PFSENSE-001] Actividad sospechosa bloqueada: corresponde a aquellas conexiones que han sido identificadas como potencialmente maliciosas y que fueron bloqueadas de manera automática por pfsense.
- [PFSENSE-002] Detectada actividad sospechosa: hace referencia a intentos de conexión o comportamientos inusuales que, si bien no han sido bloqueados en ese momento, han sido registrados para su análisis posterior.

El fin es poder saber que hay actividad sospechosa en la red que está siendo detectada o bloqueada. Además, correlacionar ofensas de otras fuentes para tener una mayor visibilidad de lo que esta ocurriendo en la red. Como en el caso de la ilustración 44.

Offense 4 Summary Display Events Flows Actions Print

Magnitude		Status		Relevance	4	Severity	5	Credibility	3
Description	Actividad sospechosa bloqueada preceded by Acceso HTTP no autorizado preceded by Petición HTTP contiene admin preceded by Descarga de EXE detectada preceded by Suspicious Activity	Offense Type	Destination IP						
Source IP(s)	Multiple (4)	Event/Flow count	234 events and 0 flows in 8 categories						
Destination IP(s)	192.168.29.1	Start	Aug 25, 2025, 4:25:01 PM						
Network(s)	Net:10-172-192_Net_192_198_0_0	Duration	9h 3m 53s						
		Assigned to	Unassigned						

List of Rules Contributing to Offense

	Rule Name	Events/Flows	First Event/Flow	Last Event/Flow
	[SURICATA-005] Petición HTTP contiene admin	3	1d 11h 14m 40s	1d 5h 36m 18s
	[SURICATA-003] Descarga no autorizada	3	1d 11h 18m 40s	1d 2h 50m 21s
	[SURICATA-004] Múltiples intentos de conexión SSH	5	1d 11h 23m 8s	1d 2h 51m 52s
	[PFSENSE-001] Actividad sospechosa bloqueada	1	1d 2h 51m 52s	1d 2h 51m 52s
	[SURICATA-001] HTTP User-Agent contiene curl	198	1d 2h 51m 56s	1d 2h 21m 15s
	[SURICATA-002] Múltiples accesos HTTP no autorizados	170	1d 11h 23m 8s	1d 2h 10m 15s

Ilustración 44. Ofensa PFsense

Para que QRadar pueda correlacionar ofensas correctamente es necesario definirlo al momento de crear la regla utilizando un indexador. En este caso es la dirección IP de destino. Así que cada vez que se genera un evento, QRadar evalúa el valor del indexador, y estos coinciden, los agrupa en una misma ofensa. Esto permite identificar

ataques o incidentes que, aunque provengan de distintas fuentes o servicios, afectan al mismo objetivo. En la ilustración 44 se puede observar un ejemplo de todas las reglas que han generado en la ofensa.

7.2 Reglas suricata

Tras las pruebas realizadas con el script de Kali Linux, se generaron una serie de eventos en la red que Wazuh pudo detectar gracias a sus reglas de monitoreo. Cada evento corresponde a una regla específica, diseñada para identificar comportamientos sospechosos o potencialmente maliciosos. A continuación, se detallan las reglas detectadas y su significado.

1. [SURICATA-001] HTTP User-Agent contiene curl: Detecta solicitudes HTTP realizadas usando la herramienta curl, que suele utilizarse para automatizar descargas o pruebas de penetración. Permite identificar accesos automatizados desde scripts o herramientas externas.
2. [SURICATA-002] Múltiples accesos HTTP no autorizados: Se activa cuando se detectan múltiples intentos de acceso a recursos web sin credenciales válidas. Indicando posibles intentos de fuerza bruta o escaneo de directorios.
3. [SURICATA-003] Descarga no autorizada: Captura intentos de descargar archivos .exe a través del comando curl. Podría tratarse de una descarga un malware.
4. [SURICATA-004] Múltiples intentos de conexión SSH: Detecta varios intentos de conexión SSH fallidos en un corto período de tiempo. Es comportamiento podría tratarse de intentos de fuerza bruta o exploración de accesos remotos.
5. [SURICATA-005] Petición HTTP contiene admin: Se activa cuando se detecta que una solicitud HTTP intenta acceder a rutas que incluyen la palabra admin. Permite identificar intentos de acceso a paneles administrativos o recursos restringidos.

Estas reglas permiten identificar patrones de ataque comunes en pruebas de seguridad y en actividad sospechosa real: automatización de accesos, intentos de fuerza bruta, descargas no autorizadas y exploración de recursos administrativos.

7.3 Reglas Wazuh

Tras las pruebas realizadas en el equipo Windows monitorizado con Wazuh se generaron varias alertas que activaron las siguientes reglas:

- [WAZUH-001] Intento de fuerza bruta: Se genera cuando existen múltiples intentos de inicio de sesión fallidos en un mismo Hostname. Permite identificar posibles ataques de fuerza bruta y actuar antes de que se logre acceso.
- [WAZUH-003] Intento de fuerza bruta exitoso: si se genera la ofensa anterior y posteriormente un evento de inicio de sesión exitoso, que indica que la fuerza bruta ha sido exitosa. Como se aprecia en la ilustración 45 para este caso es necesario la regla WAZUH-001.
- [WAZUH-002] Inicio de servicio modificado: Permite identificar cambios potencialmente peligrosos en el sistema, como la creación de entradas de autoejecución o modificaciones en configuraciones críticas.
- [WAZUH-004] Clave de registro añadida o eliminada: Detecta la creación, modificación o eliminación de claves de registro en Windows.

Apply [WAZUH-003] Intento de fuerza bruta exitoso on events which are detected by the Local system and when Inicio de sesión exitoso match at least 1 times in 1 minutes after any of [WAZUH-001] Intento de fuerza bruta match

Ilustración 45. Regla fuerza bruta exitosa

Estas reglas permiten monitorear actividad sospechosa, cambios críticos en el sistema y accesos no autorizados.

8 Conclusiones

Para concluir proyecto se van a repasar los objetivos que se plantearon al inicio de la memoria y como ha sido el resultado final. El principal era centralizar los eventos de seguridad de diversas fuentes para detectar posibles amenazas de manera más eficiente.

El primer objetivo que se tenía que cumplir para alcanzar todos los demás era la centralización de eventos de seguridad en el SIEM. Para poder llevarlo a cabo se ha implementado un QRadar donde se ha integrado las fuentes Wazuh, Suricata y Pfsense. Gracias a las pruebas llevadas a cabo en Suricata, se ha podido verificar que esto era detectado también desde Pfsense. Y no solo eso sino también actuando como prevención ya que bloquea la IP que considera una amenaza. Con esto se demuestra la importancia de centralizar los eventos de seguridad de diversas fuentes. Así logrando una visión integral del entorno y mejorando significativamente la detección de posibles amenazas.

Con el punto anterior también se cumple el segundo objetivo que es mejorar la visibilidad de red y así disminuir el tiempo de actuación de comportamientos anómalos y posibles ataques. Con las pruebas realizadas en Suricata, se detectó que Pfsense bloqueaba IPs que considera una posible amenaza. Con esto se creó una regla, así para futuros bloqueos se detectará posibles amenazas que de forma precoz. De esta forma, se reduce el tiempo de respuesta ante comportamientos anómalos y ataques.

Asimismo, la anterior detección permite la identificación de vulnerabilidades y puntos débiles en la infraestructura, permitiendo aplicar medidas correctivas y preventivas de manera más eficiente. Al generarse la regla se revisará los eventos y comprobará que la red no es susceptible a vulnerabilidades que puedan ser atacadas. O en caso contrario, que uno de los ataques haya sido efectivo, se detectará a tiempo para poder corregirlo. Esto contribuye a minimizar el riesgo de incidentes críticos.

Otro aspecto clave es la capacidad de realizar un análisis proactivo. Más allá de reaccionar ante incidentes conocidos, el SIEM permite detectar patrones y anomalías que podría ser indicativo de nuevas amenazas, anticipándose así a posibles ataques. Esta proactividad resulta esencial para mantener la seguridad de manera continua.

Finalmente, el objetivo derivado de la actividad proactiva es la compartir conocimientos sobre nuevas amenazas. No es posible demostrarlo en el trabajo debido a que se trata de un entorno de pruebas y no está expuesto a amenazas reales.

En conclusión, la integración de un SIEM y la centralización de eventos no solo refuerzan la capacidad de detección y respuesta frente a amenazas, sino que también potencian la gestión proactiva de la seguridad y la colaboración dentro del ecosistema de ciberseguridad, cumpliendo con los objetivos planteados al inicio del trabajo y demostrando la relevancia de estas herramientas en entornos digitales actuales.

8.1 Relación del trabajo desarrollado con los estudios cursados

En este apartado se va a tratar la relación que existe entre el trabajo desarrollado y los conocimientos adquiridos en el máster de Ciberseguridad y Ciberinteligencia. A lo largo del máster se han estudiado distintas herramientas de seguridad que han servido como base para poder llevar a cabo este trabajo. Gracias a esto, ha sido posible conocer qué opciones existen, cuáles se adaptan mejor a cada necesidad y, sobre todo, cuál es la utilidad de cada herramienta. No se trata únicamente de saber que existen, sino de comprender cómo funcionan y cómo pueden integrarse dentro de un entorno para mejorar su seguridad.

Una parte fundamental de la ciberseguridad es mantener la protección de los entornos, y para ello no basta con instalar herramientas defensivas de manera aislada. También es necesario centralizar todos los eventos que generan estas herramientas para tener una visión global de lo que ocurre. Además, de tener conocimiento de ataques como ofrece la matriz de MITRE, para posteriormente crear reglas de detección. De esta forma, no solo se refuerza la seguridad desde el punto de vista defensivo, sino que también se gana capacidad para anticipar posibles riesgos y reaccionar de manera más rápida y efectiva cuando surge una amenaza.

En definitiva, este trabajo me ha ayudado aplicar en la práctica lo aprendido en el máster. Me ha permitido ver el funcionamiento de las diferentes herramientas y sus posibilidades de detección. Así tener mayor experiencia en la integración de diferentes fuentes y ver como se complementan entre ellas. Y por último, ver que tipos de ataques puede detectar y así crear reglas de detección.

8.2 Trabajos futuros

En este trabajo se ha implementado una solución para centralizar los eventos de diferentes fuentes en una única plataforma de gestión. Esto permite disponer de una visión global del entorno, que facilita la monitorización y un mayor conocimiento sobre lo que ocurre en la red. Además, se ha aplicado seguridad sobre la propia infraestructura mediante un firewall. Este no solo protege el sistema frente a accesos a amenazas externas, sino que también genera y envía eventos de seguridad para que sean almacenados en un mismo lugar.

Con el objetivo de mejorar la herramienta, se podría incorporar nuevas fuentes, como por ejemplo un EDR (Endpoint Detection and Response). Este tipo de software permite detectar si se han producido infecciones por malware, intentos de explotación de vulnerabilidades y tomar acciones para paliar las posibles amenazas. Al integrar estos eventos de seguridad, se puede correlacionar dicha información con la de otras fuentes, logrando una visión más completa y precisa de la seguridad del entorno.

Además, es recomendable mejorar las reglas existentes y crear nuevas que permitan cubrir un mayor número de posibles amenazas. En el caso de Suricata, se pueden implementar reglas avanzadas para identificar tráfico anómalo, intentos de escaneo de

puertos, conexiones hacia direcciones IP maliciosas o comportamientos característicos de ataques de denegación de servicio. Con Wazuh ampliar las reglas de monitorización detección de escalada de privilegios e identificación de configuraciones sospechosas en los sistemas, fortaleciendo así la protección frente a amenazas internas y externas. Finalmente, en pfSense, definir políticas de filtrado más específicas, conexiones salientes hacia destinos sospechosos o patrones inusuales en el tráfico de red. Estas mejoras contribuirían a una mejor detección ante posibles incidentes, incrementando la capacidad de respuesta y reforzando la seguridad del entorno.

Como se comentaba, si bien el firewall constituye una primera capa de seguridad, es recomendable ir un paso más allá y realizar un proceso de bastionado de la plataforma. El CCN-CERT (Centro Criptológico Nacional) ofrece la guía de Seguridad de las TIC CCN-STIC 1203. Esto se trata de un procedimiento específico para la seguridad de la plataforma de QRadar. Esta guía contempla buenas prácticas y recomendaciones tanto en la fase previa a la instalación, durante la propia instalación, como en la configuración posterior, con el objetivo de minimizar riesgos y reforzar el sistema frente a ciberataques.

9 Bibliografía

- [1] Tubin, G. (2025, 7 enero). IBM QRadar: Key Modules, Features, Architecture, and Limitations. All-in-One Cybersecurity Platform - Cynet. Recuperado de: <https://www.cynet.com/siem/ibm-qradar-key-modules-features-architecture-and-limitations/>
- [2] IBM SIEM QRadar. (2025, 16 abril). Integra Tecnología. Recuperado de: <https://www.integratecnologia.es/ciberseguridad/ibm-security/ibm-siem-qradar>
- [3] it central _station. (2017, 4 octubre). SIEM review: Splunk, ArcSight, LogRhythm and QRadar. CSO Online. Recuperado de: <https://www.csoonline.com/article/556091/siem-review-splunk-arcsight-logrhythm-and-qradar.html>
- [4] Wazuh como nuestra principal herramienta de SOC. (s. f.). Recuperado de: <https://www.atricore.com/es/blog/wazuh-as-our-soc-main-tool>
- [5] Cilleruelo, C. (2024, 18 abril). ¿Qué es Suricata en ciberseguridad? | KeepCoding Bootcamps. KeepCoding Bootcamps. Recuperado de: <https://keepcoding.io/blog/que-es-suricata-en-ciberseguridad/>
- [6] Análisis de PfSense como una alternativa a otros firewalls comerciales – Soporte Nettix. (s. f.). Recuperado de: <https://soporte.nettix.com.pe/uncategorized/analisis-de-pfsense-como-una-alternativa-a-otros-firewalls-comerciales/>
- [7] Shethi, S. (2024, 27 agosto). VirtualBox frente a VMware: ¿Qué software de virtualización es el adecuado para usted? Geekflare Spain. Recuperado de: <https://geekflare.com/es/virtualbox-vs-vmware/>
- [8] Rodríguez, J. (2015, 11 noviembre). NAT o Bridge en la conexión de red de una máquina virtual. GEEKNETIC. Recuperado de: <https://www.geeknetic.es/Noticia/9543/NAT-o-Bridge-en-la-conexion-de-red-de-una-maquina-virtual.html>

- [9] De Luz, S. (2025, 23 mayo). Configura pfSense para proteger tu hogar o empresa con este firewall. RedesZone. Recuperado de: <https://www.redeszone.net/tutoriales/seguridad/pfsense-firewall-profesional-configuracion/>
- [10] De Luz, S. (2025a, enero 12). Configuración del router y firewall pfSense (Internet, VLANs, DHCP). RedesZone. Recuperado de: <https://www.redeszone.net/tutoriales/configuracion-routers/configuracion-router-firewall-pfsense/#389950-configurar-reglas-en-el-firewall>
- [11] Try QRADAr SIEM | IBM Security QRADar Community Edition - 101. (2025, 25 agosto). 101. Recuperado de: <https://www.ibm.com/community/101/qradar/ce/>
- [12] Sixe. (2024b, agosto 26). Instala en diez minutos la versión 7.3.3 de QRadar Community Edition. SIXE. Recuperado de: <https://sixe.es/noticias/ciberseguridad/como-instalar-qradar-community-edition-7-3-3>
- [13] IBM Support. (s. f.). Recuperado de: https://www.ibm.com/mysupport/s/defect/aCIoz0000004cHJ/dto52197?language=en_US
- [14] Qj. (2025, 7 abril). Wazuh: Plataforma de seguridad integral de código abierto. QJ. Recuperado de: <https://blog.qjorge.com/wazuh-plataforma-de-seguridad-integral-de-codigo-abierto/>
- [15] Wazuh. (s. f.). Installing the Wazuh agent from sources - Installation from sources. Recuperado de: <https://documentation.wazuh.com/current/deployment-options/wazuh-from-sources/wazuh-agent/index.html>
- [16] Tin3r. (2025, 25 julio). Detección de intrusos con Suricata - Lathack. Lathack. Recuperado de: <https://lathack.com/seguridad-informatica/deteccion-de-intrusos-con-suricata/>
- [17] IBM QRADAR Security Intelligence Platform. (s. f.). Recuperado de: <https://www.ibm.com/docs/es/dsm?topic=configuration-protocol-options>

[18] *IBM QRadar on Cloud*. (s. f.-b). Recuperado de:
<https://www.ibm.com/docs/es/qradar-on-cloud?topic=problems-troubleshooting-dsms>

[19] IBM QRADAR Security Intelligence Platform. (s. f.-b). Recuperado de:
<https://www.ibm.com/docs/es/qradar-common?topic=apps-qradar-log-source-management-app>

[20] 8. Suricata Rules — Suricata 8.0.1-dev documentation. (s. f.). Recuperado de:
<https://docs.suricata.io/en/latest/rules/index.html>

[21] *Sending alerts via syslog — OSSEC*. (s. f.). Recuperado de:
<https://www.ossec.net/docs/docs/manual/output/syslog-output.html>

[22] Sending alerts via syslog — OSSEC. (s. f.). Recuperado de:
<https://www.ossec.net/docs/docs/manual/output/syslog-output.html>

[23] Suricata - testmyids. (2021, 4 abril). Suricata. Recuperado de:
<https://forum.suricata.io/t/suricata-testmyids/1266>

[24] UPDATED: A QRadar deploy changes on 31 December 2020 can impact product functionality. (s. f.). Recuperado de:
<https://www.ibm.com/support/pages/node/6395080>

ANEXO

OBJETIVOS DE DESARROLLO SOSTENIBLE

Grado de relación del trabajo con los Objetivos de Desarrollo Sostenible (ODS).

Objetivos de Desarrollo Sostenibles	Alto	Medio	Bajo	No Procede
ODS 1. Fin de la pobreza.				X
ODS 2. Hambre cero.				X
ODS 3. Salud y bienestar.				X
ODS 4. Educación de calidad.				X
ODS 5. Igualdad de género.				X
ODS 6. Agua limpia y saneamiento.				X
ODS 7. Energía asequible y no contaminante.				X
ODS 8. Trabajo decente y crecimiento económico.	X			
ODS 9. Industria, innovación e infraestructuras.		X		
ODS 10. Reducción de las desigualdades.				X
ODS 11. Ciudades y comunidades sostenibles.				X
ODS 12. Producción y consumo responsables.				X
ODS 13. Acción por el clima.				X
ODS 14. Vida submarina.				X
ODS 15. Vida de ecosistemas terrestres.				X
ODS 16. Paz, justicia e instituciones sólidas.				X
ODS 17. Alianzas para lograr objetivos.				X



Reflexión sobre la relación del TFG/TFM con los ODS y con el/los ODS más relacionados.

En este trabajo, el objetivo principal ha sido crear un entorno seguro mediante la integración de herramientas como SIEM, HIDS, NIDS y firewall para centralizar y analizar los eventos de seguridad. A la hora de relacionarlo con los Objetivos de Desarrollo Sostenible (ODS), se observa que la mayoría de los ODS, como fin de la pobreza, hambre cero, salud y bienestar, igualdad de género o educación de calidad, no tienen una relación directa con el trabajo realizado. Esto se debe a que el TFM se centra en la seguridad informática y en la protección de entornos digitales, más que en cuestiones sociales y medioambientales. Por eso, para esos ODS, la relación se marca como “No procede”.

Sin embargo, sí se puede establecer un vínculo más claro con algunos ODS desde un punto de vista indirecto, especialmente los relacionados con la innovación, la industria y el crecimiento económico. Para este caso se ve reflejado en la medida en que la seguridad informática es fundamental para las empresas ya que un entorno protegido frente a ciberataques garantiza la continuidad de los negocios y protege la economía.

También hay una relación con el ODS 9 (Industria, innovación e infraestructuras). El trabajo contribuye a la construcción de infraestructuras digitales más seguras, y fomenta la innovación en la forma de integrar herramientas de ciberseguridad. La centralización de eventos y la monitorización proactiva permite que las organizaciones puedan detectar problemas antes de que se conviertan en incidentes graves, algo que fortalece la infraestructura tecnológica y promueve el desarrollo de soluciones más inteligentes.

Por otro lado, aunque los ODS relacionados con el medio ambiente, como acción por el clima o vida de ecosistemas terrestres y submarinos, no están directamente vinculados con la ciberseguridad, se podría argumentar una relación indirecta con la eficiencia energética y el uso responsable de los recursos digitales. Mantener sistemas seguros evita pérdidas de información, fallos en la infraestructura y, en algunos casos, un consumo extra de energía derivado de incidentes o recuperaciones de sistemas. No obstante, esta conexión es bastante débil y por eso se marca como “No procede” en la tabla.

En términos generales, mi reflexión es que, aunque el trabajo se centra en un área muy específica y técnica, como es la ciberseguridad, sí tiene un impacto real en la sostenibilidad del desarrollo económico y en la innovación tecnológica. Garantizar la protección de los entornos digitales es, hoy en día, una pieza clave para que las empresas, instituciones y ciudadanos puedan operar de manera segura y confiable.



En conclusi3n, aunque la mayoría de los ODS no se aplican directamente a mi TFM, sí se puede ver una relaci3n significativa con aquellos vinculados al crecimiento econ3mico, la innovaci3n y la infraestructura tecnol3gica.

